

CloudShield AI

08 — Security & Threat Model Specification

Version 1.0 | Product-Level Engineering Specification

CloudShield AI / CloudSpartanX

Document purpose: Define the security architecture, threat model, security controls, failure behavior, testing requirements, and MVP security baseline for CloudShield AI. This specification covers the complete product and treats DAIL as an integrated safety-critical subsystem.

Canonical security principle: AI proposes. Deterministic systems validate. Governance decides. Cloud APIs execute. Evidence records. Trusted state is earned.

1. Purpose and Scope

This document establishes the security requirements and threat model for CloudShield AI across the product, platform, intelligence, security, infrastructure, and DAIL subsystem layers.

- Protect cloud credentials, customer data, infrastructure metadata, findings, recommendations, candidates, evidence, and audit records.
- Prevent unauthorized access, cross-tenant data exposure, unsafe infrastructure changes, and loss of evidence integrity.
- Constrain AI systems so that model output cannot directly obtain unrestricted production authority.
- Define security controls at trust boundaries and at every state transition that can increase operational authority.
- Provide a threat-informed baseline for MVP implementation and a path toward stronger production hardening.

Out of scope for this document: detailed API schemas, complete AWS/Terraform implementation details, full DAIL functional specifications, and organization-specific compliance mappings. Those are governed by their dedicated specifications.

2. Security Objectives and Principles

ID	Objective	Requirement
SEC-OBJ-01	Confidentiality	Prevent unauthorized disclosure of credentials, tenant data, infrastructure metadata, AI context, and evidence.
SEC-OBJ-02	Integrity	Ensure observations, candidates, approvals, verification results, trusted state, and evidence cannot be silently altered.
SEC-OBJ-03	Availability	Keep discovery, analysis, verification, and evidence functions resilient enough to support safe operations.

ID	Objective	Requirement
SEC-OBJ-04	Authorization	Enforce least privilege, explicit scopes, role/policy checks, and separation of duties.
SEC-OBJ-05	Safety	Prevent AI or untrusted inputs from directly causing unauthorized or unverified infrastructure changes.
SEC-OBJ-06	Traceability	Make security-relevant actions attributable to actor, tenant, scope, time, version, and evidence.
SEC-OBJ-07	Isolation	Maintain strong tenant and environment boundaries.
SEC-OBJ-08	Recoverability	Support detection, containment, reconciliation, rollback where possible, and forensic reconstruction.

2.1 Security principles

- Least privilege by default; permissions are scoped to the smallest practical tenant, account, region, resource, and operation boundary.
- Default deny for privileged operations and sensitive data access.
- Fail closed at safety gates when required evidence, verification, authorization, or policy state is missing.
- No implicit trust transfer from AI output to cloud authority.
- Explicit separation between observed, proposed, verified, and trusted state.
- Immutable or append-only treatment for security-critical evidence and audit records.
- Defense in depth across application, identity, network, data, AI, cloud, and operational layers.
- Assume external cloud state can drift or become inconsistent; re-check critical assumptions before promotion.
- Security controls must be testable and observable rather than relying only on documentation or operator intent.

3. Security Architecture

3.1 Product security zones

Zone	Components	Primary Security Concern
User / Browser	Web UI, user session	Authentication, session security, XSS/CSRF, authorization presentation.
Application	API, application services, domain logic	Authorization, validation, tenant isolation, business-rule enforcement.
Intelligence	AI abstraction, context assembly, model adapters	Prompt injection, data minimization, tool isolation, output validation.
Control / DAIL	Candidate, impact, verification, promotion controls	Unsafe change prevention, invariant enforcement, state integrity.
Cloud Integration	AWS adapters, discovery, execution	Credential scope, API authorization, cloud-side blast radius.
Data	Relational DB, object storage, queue/job state	Confidentiality, integrity, retention, access control.

Zone	Components	Primary Security Concern
Evidence / Operations	Audit, evidence, logs, monitoring	Tamper resistance, forensic value, alerting, retention.

3.2 Security control plane

CloudShield AI should treat authorization, policy evaluation, candidate validation, verification gates, audit/evidence capture, and promotion controls as a security control plane. Business features must not bypass these controls by calling cloud APIs directly.

3.3 Trust elevation model

Authority must increase only through explicit gates. A typical path is: untrusted input → authenticated request → authorized action → validated domain object → verified candidate → governed approval → controlled promotion → trusted state. Each transition records the evidence necessary to justify the new state.

4. Assets and Data Classification

Classification	Examples	Handling Baseline
Critical	Cloud credentials/tokens, signing material, privileged execution secrets, authorization policy state	Strong secret management; never expose to models or client; tightly scoped access; audit every use.
Highly Sensitive	Tenant infrastructure metadata, configuration snapshots, candidate payloads, AI context, findings, evidence artifacts	Tenant-scoped authorization; encryption; controlled retention; redacted logs.
Sensitive	Audit events, job metadata, dependency graphs, risk assessments, reports	Authenticated access; tenant isolation; integrity controls; appropriate retention.
Internal	Operational metrics, non-sensitive configuration, service metadata	Access controlled; avoid unnecessary exposure.
Public	Documentation or explicitly public product information	No customer-sensitive content; normal integrity controls.

Classification is a default baseline. Tenant-specific policy may require stricter handling. Sensitive information must be minimized before it enters prompts, logs, telemetry, exports, or error messages.

5. Trust Boundaries

Boundary	Crossing Data/Authority	Required Controls
TB-01 Browser ↔ API	Identity, requests, results	TLS, authentication, CSRF/session controls as applicable, authorization, input validation.
TB-02 User ↔ Tenant	Tenant-scoped operations	Tenant derived from trusted identity/session context; never trusted from arbitrary client fields.
TB-03 API ↔ Cloud	Cloud API calls and credentials	Scoped identity, short-lived credentials where supported, operation allowlists, audit.
TB-04 Application ↔ LLM	Prompts, context, model output	Data minimization, prompt isolation, output schema validation, no unrestricted tools.

Boundary	Crossing Data/Authority	Required Controls
TB-05 LLM ↔ Tools	Potential tool requests	Brokered tool execution, explicit allowlists, authorization independent of model output.
TB-06 Candidate ↔ Promotion	Infrastructure-affecting authority	Exact-version binding, impact analysis, verification, approval/policy, re-checks.
TB-07 Service ↔ Data Store	Customer and security state	Service identity, least privilege, encryption, integrity constraints.
TB-08 Product ↔ External Integration	Third-party data/actions	Scoped credentials, validation, rate limits, provenance, failure isolation.
TB-09 Evidence ↔ Operators	Forensic/security records	Append-only semantics where practical, integrity protection, restricted modification.

6. Threat Actors

Actor	Capability / Motivation	Primary Risks
Unauthenticated attacker	Internet-accessible probing	API abuse, injection, enumeration, denial of service.
Compromised user	Valid but stolen identity	Data access, privilege misuse, malicious candidates.
Malicious insider	Legitimate platform access	Tenant exposure, unauthorized promotion, evidence manipulation.
Compromised cloud identity	Valid cloud permissions	Resource modification, discovery abuse, credential theft.
Malicious or compromised integration	External system access	Data poisoning, unauthorized actions, supply-chain compromise.
Adversarial prompt/content source	Can influence text/configuration reaching AI	Prompt injection, instruction hijacking, data exfiltration, unsafe recommendations.
Compromised model/provider path	Model response or service behavior is manipulated	Incorrect recommendations, data leakage, tool abuse.
Supply-chain attacker	Compromised dependency/build artifact	Code execution, secret theft, persistence.

7. Attack Surface

- Web application and browser-facing APIs.
- Authentication, authorization, sessions, tokens, service identities, and administrative functions.
- Cloud onboarding and credential/configuration exchange.
- AWS discovery APIs and any future cloud execution APIs.
- Infrastructure configuration payloads, Terraform plans, templates, policy files, and uploaded artifacts.
- AI prompts, retrieved cloud context, model outputs, tool interfaces, and provider integrations.
- Remediation candidates and promotion endpoints.
- Dependency graph ingestion and relationship reconstruction.
- Evidence, reports, exports, logs, and audit interfaces.
- Background workers, queues, job payloads, scheduled discovery, and webhook/event inputs.
- Third-party libraries, containers, CI/CD systems, infrastructure-as-code modules, and deployment artifacts.

8. Threat Taxonomy

8.1 STRIDE-oriented threats

Category	CloudShield AI Examples	Core Mitigation
Spoofing	Stolen session, forged service identity	Strong authentication, token validation, service identity.
Tampering	Modified candidate, evidence, dependency edge, policy	Integrity checks, immutable versions, authorization, audit.
Repudiation	Actor denies promotion or configuration action	Attributable audit events and evidence.
Information Disclosure	Cross-tenant findings, prompt context leakage, credential exposure	Tenant isolation, minimization, encryption, redaction.
Denial of Service	Expensive discovery, AI request floods, queue exhaustion	Rate limits, quotas, backpressure, job controls.
Elevation of Privilege	User reaches admin/promotion capability	RBAC/ABAC, policy checks, separation of duties, server-side authorization.

9. Cloud Credential and IAM Threats

9.1 Threats

- Long-lived cloud access keys are leaked through source code, logs, tickets, prompts, client storage, or crash artifacts.
- A discovery identity is accidentally granted mutation permissions.
- A compromised CloudShield service uses an overly broad cloud role.
- Cross-account or cross-region access is unintentionally exposed.
- Credential rotation/revocation leaves stale sessions or cached authority active.
- Cloud-side policy changes invalidate assumptions used during verification or promotion.

9.2 Controls

- Prefer short-lived, role-based cloud credentials and workload identity mechanisms where available.
- Separate read/discovery credentials from change-execution credentials.
- Maintain explicit permission profiles for discovery, analysis, verification, and promotion.
- Do not persist secrets in relational records unless unavoidable; use a dedicated secret-management mechanism.
- Never place raw cloud secrets in prompts, application logs, browser state, evidence exports, or error messages.
- Require fresh authorization and precondition checks for high-impact operations.
- Alert on unexpected use of privileged cloud identities.

10. Tenant Isolation Threat Model

- Tenant identity must be derived from authenticated server-side context, not trusted client-supplied tenant identifiers.
- Every tenant-owned entity must have an authorization path that proves tenant membership before read or write.
- Background jobs must carry explicit tenant/scope context and must not infer it from mutable payload data.

- Object-storage keys and database queries must enforce tenant boundaries.
- Exports and reports must be generated under tenant authorization, including asynchronous jobs.
- Caches must include tenant/scope identity in keys to prevent data bleed.
- Administrative cross-tenant operations must be exceptional, explicit, and audited.

Threat	Failure Condition	Required Response
Horizontal data access	User can query another tenant's asset/finding	Reject request; log security event; alert if repeated.
Cross-tenant job execution	Worker processes wrong tenant scope	Fail job closed; quarantine payload; preserve evidence.
Cache bleed	Tenant A receives Tenant B result	Invalidate affected cache; incident response; prevent recurrence.
Export leakage	Report contains unauthorized tenant data	Block export; generate security event; require reauthorization.

11. Web and API Security

- Authenticate every protected endpoint and authorize every security-sensitive operation server-side.
- Validate request structure, types, sizes, identifiers, and state transitions.
- Use parameterized database access and safe serialization.
- Protect browser sessions with appropriate secure cookie/token practices, CSRF defenses where cookie-based authentication is used, and secure logout/revocation behavior.
- Apply rate limits and quotas to authentication, discovery, AI, report generation, and promotion endpoints.
- Avoid detailed error messages that reveal credentials, tenant existence, infrastructure secrets, internal stack traces, or security-sensitive state.
- Use idempotency keys for operations that could otherwise be repeated dangerously.
- Require optimistic concurrency/version checks on candidate and approval operations.

12. AI / LLM Threat Model

12.1 AI security position

The AI layer is an untrusted reasoning component from a security-authority perspective. Model output may inform humans and deterministic services, but it cannot by itself authorize cloud mutation or promotion.

12.2 Threats

Threat	Example	Control
Direct prompt injection	User tells model to ignore policy and expose secrets	Instruction hierarchy, context isolation, output validation, no secret inclusion.
Indirect prompt injection	A cloud resource description, tag, document, or log contains hostile instructions	Treat retrieved content as data, not instructions; delimit/untrusted-label content; deterministic policy checks.
Data exfiltration	Model is induced to reveal tenant data or credentials	Data minimization, redaction, access-scoped context, output filtering.
Tool abuse	Model attempts an unauthorized cloud/API action	Brokered tools, allowlists, independent authorization, no direct credentials.

Threat	Example	Control
Hallucinated remediation	Model invents a resource, parameter, or safe change	Schema validation, resource identity resolution, policy checks, verification.
Instruction smuggling	Malicious content changes meaning of system instructions	Structured context, provenance, strict tool contracts, canonical policy evaluation.
Model/provider compromise	External model service returns manipulated output	Treat output as untrusted; deterministic validation; provider isolation; evaluation.
Sensitive retention	Prompt data retained by provider unexpectedly	Provider policy review, minimization, configurable retention, avoid unnecessary sensitive data.

12.3 AI boundary rules

- The AI abstraction layer must expose structured request/response contracts.
- Model outputs must be parsed against strict schemas and rejected when malformed or incomplete.
- The model must not receive unrestricted cloud credentials.
- Any tool request must pass through a policy-enforcing broker independent of the model.
- AI-generated infrastructure changes must become explicit RemediationCandidate objects before any verification or promotion.
- The candidate must be bound to exact input/context versions sufficient for reproducibility.
- AI explanations are advisory and must not be treated as proof of correctness.
- High-impact recommendations require deterministic checks and human/policy governance.

13. Remediation and Change-Execution Threats

Threat	Risk	Security Gate
Malicious candidate	User/AI submits destructive change	Authorization + schema validation + policy + impact + verification.
Candidate mutation after verification	Verified artifact differs from promoted artifact	Immutable versioning + exact-version binding.
TOCTOU cloud drift	Cloud state changes after verification	Fresh pre-promotion checks + reconciliation.
Over-broad execution	Valid candidate changes unintended resources	Explicit target set + least privilege + impact boundary.
Replay	Old promotion request executed again	Idempotency + candidate/version status + authorization.
Partial execution	Some resources changed, others failed	Explicit outcome states + reconciliation + evidence.
Unknown outcome	Network timeout hides whether change succeeded	Reconciliation before retry; do not blindly replay.
Emergency bypass abuse	Operator bypasses gates	Exceptional path, strict role, reason, expiry, full audit.

14. DAIL-Specific Security Threats

DAIL is a safety-critical subsystem inside CloudShield AI. Its security objective is to ensure lifecycle controls cannot be bypassed when infrastructure authority is being elevated.

- Candidate identity confusion causes verification to apply to the wrong artifact.
- Dependency data is stale, incomplete, or maliciously manipulated.
- Impact analysis falsely reports a bounded blast radius.
- Verification results are replayed against a different candidate version.
- Approval remains valid after a protected candidate or context changes.
- Promotion bypasses one or more required gates.
- Trusted state is written without successful governed promotion.
- Evidence is missing, altered, or disconnected from the lifecycle event.
- A privileged service can invoke promotion without satisfying application-level governance.

14.1 DAIL security controls

- Stable deterministic identity for candidates, assets, and dependency references.
- Exact candidate-version binding for verification and promotion.
- Fail-closed behavior when mandatory evidence or verification is absent.
- No silent merge on ambiguous asset identity or dependency identity.
- Critical dependency assumptions re-checked before promotion.
- Approval invalidation when protected candidate/context changes.
- Promotion endpoint independently enforces lifecycle gates rather than trusting UI state.
- Trusted state is earned only through recorded successful promotion.
- Every security-relevant transition emits attributable audit/evidence records.

15. Dependency and Impact Manipulation Threats

- Attackers may inject false dependency relationships to hide or exaggerate blast radius.
- Stale edges may make a change appear safe when downstream resources are actually affected.
- Ambiguous identity may merge two resources and corrupt graph semantics.
- Missing telemetry may create a false impression of a complete dependency graph.
- A malicious configuration/tag/document can poison inferred relationships.

Security requirement: unknown or incomplete dependency information must not be interpreted as a clean or bounded result. Impact analysis must communicate confidence, provenance, freshness, and unknowns. Safety-critical decisions must fail closed when required dependency evidence is unavailable.

16. Evidence and Audit Integrity

- Audit events must identify actor/service identity, tenant, scope, action, target, timestamp, result, correlation ID, and relevant object/version identifiers.
- Security-critical evidence should be append-only or tamper-evident.
- Evidence references must remain bound to the exact candidate, verification run, approval, and promotion event they support.
- Operators must not be able to silently rewrite historical security decisions.
- Logs should redact secrets and unnecessary sensitive payloads.
- Time synchronization and consistent event timestamps are required for meaningful forensic reconstruction.
- Security events must be exportable to monitoring/SIEM systems without weakening tenant isolation.

17. Supply-Chain and Dependency Security

- Pin and review production dependencies and container/base images.
- Run dependency and vulnerability scanning in CI.
- Use reproducible or traceable build artifacts where practical.
- Protect CI/CD credentials and signing material.
- Review third-party AI SDKs, cloud SDKs, Terraform providers/modules, and browser dependencies.
- Maintain a software bill of materials capability as maturity increases.
- Separate build identities from runtime identities.
- Do not permit unreviewed dependency updates to reach production execution paths.

18. Secrets Management

Secret Type	Storage	Exposure Rule
Cloud credentials	Dedicated secret/identity mechanism	Never browser-visible; never prompt-visible; minimum required scope.
Application secrets	Secret manager/environment injection	No source control; no logs; rotate on schedule/event.
Signing keys	Protected key-management service	Use only through controlled service identity.
AI provider credentials	Secret manager	Server-side only; never sent to client/model.
Webhook secrets	Secret manager	Validate signatures before processing payloads.

19. Network and Transport Security

- Encrypt all external and service-to-service traffic using TLS.
- Minimize public exposure of internal services and data stores.
- Restrict egress from workloads that do not require arbitrary internet access.
- Use private connectivity to cloud services where practical for production deployments.
- Separate management, application, worker, and data-plane network paths as maturity requires.
- Apply network-level controls as a second layer rather than relying on them as the only authorization mechanism.

20. Encryption and Data Protection

- Encrypt sensitive data at rest using managed encryption capabilities appropriate to the deployment environment.
- Encrypt all sensitive traffic in transit.
- Use key rotation and access controls for encryption keys.
- Minimize retained cloud configuration and AI context to what is required for product functionality.
- Define retention classes for findings, snapshots, evidence, audit records, and job artifacts.
- Support secure deletion/expiration for data subject to tenant retention requirements.
- Treat backups as sensitive copies with equivalent access controls.

21. Security Monitoring and Incident Response

21.1 Security telemetry

- Authentication failures and anomalous login behavior.
- Authorization denials and repeated forbidden operations.
- Privileged cloud credential use.
- Promotion attempts, bypass attempts, and verification failures.
- Cross-tenant authorization anomalies.
- AI tool/policy violations and suspicious prompt patterns.
- Unexpected dependency/identity conflicts.
- Evidence integrity failures.
- Unusual discovery volume, queue growth, or API consumption.

21.2 Incident response lifecycle

1. Detect and generate a security event.
2. Classify severity and affected tenant/scope.
3. Contain affected identity, token, service, job, or integration.
4. Preserve relevant evidence and audit context.
5. Determine whether cloud state, candidate state, or trusted state was affected.
6. Reconcile external cloud state where execution outcome is ambiguous.
7. Remediate the vulnerability or compromised authority.
8. Validate recovery and restore safe operation.
9. Record root cause, controls that failed, and required follow-up.

22. Security Control Matrix

Control ID	Control	Layer	Priority	Verification
SC-01	Server-side authentication and authorization	Application	P0	Automated authz tests + review
SC-02	Tenant isolation on every tenant-owned operation	Platform	P0	Cross-tenant negative tests
SC-03	Least-privilege cloud identities	Cloud	P0	IAM policy review + integration test
SC-04	Secrets never exposed to client/log/model	Platform/AI	P0	Secret scanning + runtime tests
SC-05	Strict AI output schema validation	AI	P0	Malformed/adversarial evaluation
SC-06	No direct AI-to-cloud authority	AI/Cloud	P0	Architecture test + code review
SC-07	Candidate immutable versioning	DAIL	P0	Concurrency/version tests
SC-08	Verification bound to exact candidate version	DAIL	P0	Negative promotion tests
SC-09	Fresh pre-promotion safety checks	DAIL/Cloud	P0	Drift simulation

Control ID	Control	Layer	Priority	Verification
SC-10	Evidence/audit integrity	Operations	P0	Tamper/append-only tests
SC-11	TLS for protected communication	Network	P0	Configuration/security scan
SC-12	Rate limiting and quotas	API	P1	Load/abuse tests
SC-13	Dependency vulnerability scanning	Supply chain	P1	CI gate
SC-14	Security alerting/SIEM integration	Operations	P1	Synthetic event validation
SC-15	Backup and recovery controls	Data	P1	Restore test
SC-16	SBOM and artifact provenance	Supply chain	P2	Build pipeline review

23. Security State and Fail-Closed Rules

Condition	Required State/Behavior
Authentication unavailable	Protected operation rejected.
Tenant context ambiguous	Operation rejected; no default tenant selection.
Authorization uncertain	Deny.
Required dependency evidence missing	Do not claim safe/bounded impact; block safety-critical promotion.
Verification incomplete	Promotion blocked.
Candidate version changed after verification	Verification/approval invalidated.
Cloud state changed materially after verification	Re-verify or reconcile; do not blindly promote.
Promotion outcome ambiguous	Enter reconciliation state; do not blindly retry.
Evidence write fails for a required security event	Security-critical operation must fail closed or enter explicit recovery state.
AI output malformed/untrusted	Reject output; no candidate creation from invalid response.
Policy service unavailable for mandatory gate	Fail closed for the protected operation.

24. Security Testing Requirements

24.1 Test categories

- Unit tests for authorization, policy evaluation, state transitions, identity resolution, and redaction.
- Integration tests for cloud identity scope and API permissions.
- Cross-tenant negative tests.
- API security tests including injection, malformed input, replay, rate-limit, and authorization bypass attempts.
- AI red-team tests for direct/indirect prompt injection, exfiltration, tool abuse, hallucinated resources, and instruction smuggling.
- DAIL adversarial tests for candidate mutation, stale verification, approval invalidation, dependency poisoning, replay, and promotion bypass.
- Evidence tampering and audit-integrity tests.
- Dependency and container vulnerability scanning.

- Dynamic application security testing as deployment maturity permits.
- Recovery and incident-response exercises for privileged identity compromise and ambiguous cloud execution.

24.2 Security quality gates

Gate	Minimum Condition
Build gate	No known critical dependency/build vulnerability accepted without explicit exception.
Unit gate	All P0 authorization and state-safety tests pass.
Integration gate	Cloud IAM boundaries verified against intended operations.
AI gate	Critical prompt-injection/tool-abuse evaluations pass.
DAIL gate	No tested path bypasses required verification/promotion controls.
Release gate	Security logs, secrets handling, tenant isolation, and rollback/recovery checks pass.

25. MVP Security Baseline

- Authenticated users with server-side authorization and tenant isolation.
- AWS discovery through least-privilege read identities.
- No unrestricted production mutation capability from AI.
- AI abstraction layer with strict structured output validation.
- Explicit RemediationCandidate lifecycle with immutable versions.
- Impact and verification gates before promotion.
- Human/policy approval for configured high-impact changes.
- Secrets stored outside source code and client-visible state.
- Encryption in transit and at rest for sensitive data.
- Security-relevant audit and evidence capture.
- Rate limits, request validation, secure error handling, and basic abuse protection.
- Dependency scanning and protected CI/CD secrets.
- Monitoring for authentication, authorization, privileged actions, verification failures, and promotion anomalies.
- Recovery path for ambiguous external cloud outcomes.

26. Future Security Hardening

- Fine-grained ABAC and policy-as-code across all privileged workflows.
- Short-lived workload identity throughout the deployment topology.
- Dedicated policy decision service and stronger separation of duties.
- Hardware-backed/key-management-backed signing and artifact attestations.
- SBOM, provenance, and software supply-chain attestation.
- Dedicated graph infrastructure for large-scale dependency analysis where justified.
- Expanded AI red-team/evaluation framework and model-provider isolation.
- Continuous attack-surface management and automated security regression testing.
- Advanced anomaly detection for cloud identity and promotion behavior.
- Formal compliance control mappings based on target customer requirements.

27. Traceability to Previous Specifications

Source	Security Dependency
00 — Master System Specification	Product boundary, actors, trust model, governance, DAIL positioning.
01 — Software Requirements Specification	Security, privacy, reliability, authorization, AI abstraction, verification and promotion requirements.
02 — System Architecture Specification	Service boundaries, data architecture, cloud integration, trust boundaries, deployment and failure model.
03 — Functional Specification	User actions, candidate lifecycle, verification, approval, promotion, drift, jobs, and error behavior.
04 — Product & UX Specification	Safe-path UX, confirmation, stale/partial/error states, security/privacy interaction patterns.
05 — Domain & Data Model	Tenant, identity, candidate, evidence, audit, policy, verification, promotion, trusted-state objects.
06 — State & Lifecycle Specification	Fail-closed transitions, version binding, invalidation, reconciliation, trusted-state rules.
07 — Identity & Dependency Specification	Stable identity, dependency provenance, graph integrity, impact confidence, and dependency-related invalidation.

28. Security Acceptance Criteria

10. A user cannot read or modify another tenant's resources through any tested product path.
11. A discovery identity cannot perform mutation operations outside its explicitly granted scope.
12. Raw cloud credentials never appear in browser responses, logs, evidence exports, or AI prompts.
13. Malformed or adversarial AI output cannot directly produce a trusted infrastructure state.
14. A verified candidate cannot be promoted if its exact version has changed.
15. A candidate cannot reach promotion when mandatory impact/verification/approval gates are missing.
16. Material cloud drift after verification invalidates or forces re-evaluation of the affected safety decision.
17. Ambiguous cloud execution outcomes enter reconciliation rather than blind retry.
18. Security-critical evidence is attributable and protected against silent alteration.
19. Required security events are observable through application/operational telemetry.
20. MVP CI/CD blocks known critical dependency vulnerabilities unless an explicit, auditable exception exists.
21. Security tests cover authentication, authorization, tenant isolation, AI abuse, DAIL bypass, evidence integrity, and cloud IAM boundaries.

29. Security Design Summary

CloudShield AI security is built around controlled authority rather than model trust. The system must assume that users, cloud data, external integrations, AI inputs, and model outputs can be malicious or incorrect. Security therefore depends on explicit identity, least privilege, tenant isolation, deterministic validation, exact-version lifecycle controls, evidence integrity, and fail-closed promotion.

The decisive boundary is between recommendation and authority: AI may reason and recommend, but only deterministic controls and governance may authorize a change. DAIL enforces that lifecycle boundary as a subsystem, while CloudShield AI as a whole supplies identity, cloud context, risk intelligence, policy, evidence, operations, and user governance.

30. Glossary

Term	Definition
CloudShield AI	The complete cloud security and infrastructure intelligence product.
DAIL	Deterministic AI Infrastructure Lifecycle subsystem controlling candidate-to-trusted lifecycle safety.
AI Abstraction Layer	Provider-neutral interface separating CloudShield AI from a specific hosted or local model.
Candidate	Explicit proposed infrastructure change that can be validated, governed, and promoted.
Trusted State	State earned after successful governed promotion and corresponding evidence.
Tenant	Security and data-isolation boundary representing an organization/customer context.
Dependency Edge	Canonical relationship describing how one infrastructure asset relates to another.
Impact Analysis	Evaluation of resources and relationships potentially affected by a candidate.
Verification	Deterministic or controlled execution of checks establishing whether a candidate satisfies required gates.
Promotion	Governed operation that applies an approved verified candidate to the target environment.
Evidence	Artifact or record supporting a security, lifecycle, verification, or governance decision.